Paso 3 | Evaluación de arquitectura y flujo

Anexo técnico para adjuntar a los dos diagramas originales. Versión revisada · 04 de noviembre de 2026

PROPÓSITO

Conservar los diagramas de arquitectura lógica y flujo comercial como modelos académicos, sin elevar a hechos las conexiones, secuencias y controles que el enunciado no autentica. Las relaciones supuestas se convierten en preguntas de auditoría y pruebas solicitadas, nunca en incumplimientos ya confirmados.

Nota metodológica para colocar junto a ambos diagramas

Este diagrama es un modelo lógico de referencia construido a partir de los componentes y funciones descritos en el caso RedNova Guatemala, S. A. Las relaciones de integración, dependencias, ubicación de sistemas, rutas de datos y controles no descritos explícitamente son supuestos de análisis sujetos a verificación. Su representación no demuestra implementación, eficacia, incumplimiento ni causa del incidente. Los códigos E-01 a E-10 representan señales preliminares, no extracciones autenticadas de sistemas.

Leyenda de certeza

Etiqueta	Significado	Tratamiento
D · Documentado	Componente/función/evento aparece en el caso	Puede citarse como declaración del caso; no confirma configuración detallada.
S · Supuesto técnico	Interacción o secuencia plausible, no especificada	Marcar “por verificar”; solicitar documentación técnica.
C · Control esperado	Comportamiento de seguridad o gobierno deseable	Usarlo para definir prueba/criterio, no afirmar que está implementado.
E · Evidencia preliminar	Resumen E-01–E-10 o cronología aportada	Contrastar origen, integridad, alcance y contexto antes de concluir.
H · Hallazgo	Desviación sustentada frente a un criterio aplicable	No se marca ninguno en el Paso 3 sin prueba suficiente.

1. Evaluación del diagrama de arquitectura lógica

Archivo adjunto: 01_Arquitectura_Logica_Con_Notas.pdf. El diagrama original se conserva sin alterar nodos o relaciones. El cuadro siguiente identifica el grado de certeza de sus partes.

ID	Elemento representado	Tipo	Evaluación y validación
A-01	CRM, SQL Server, ERP, móvil	D	Inventario tecnológico, funciones generales; no topología.
A-02	Identidad/VPN, SIEM y nube/respaldos	D	Existen como categorías del caso; cobertura y ubicación específicas no descritas.
A-03	Chatbot con IA y API	D	Se identifican en inventario; no se conoce su arquitectura ni proveedor específico.

A-04	Móvil → API → CRM	S	Pedir diagrama de integración y contratos de API; no afirmar que esta ruta está activa.
A-05	VPN → API / sesión de proveedores	S	Pedir topología, registros VPN y asignación de permisos. E-02 es indicio inicial.
A-06	CRM ↔️ SQL Server	S	Coexistencia y funciones documentadas; dependencia directa por confirmar.
A-07	CRM ↔️ ERP ↔️ SQL Server	S	Pedir interfaces, reconciliaciones y propietarias de datos; no asumir acceso directo.
A-08	Cloud → API / backups	S	Nube híbrida y respaldos existen; localización, operación y restauración pendientes.
A-09	Chatbot ubicado bajo “proveedores/nube”	S	Su ubicación/tercerización no consta. La frontera dibujada es preliminar.
A-10	Todos los componentes → SIEM	C	Cobertura, integridad, retención, sincronización y alertas deben comprobarse.
A-11	MFA / permisos / traza en API	C	Controles esperados; el caso presenta alertas sobre accesos y permisos.
A-12	Fronteras A–B–C	S	Son agrupaciones de análisis, no evidencia de propiedad o hosting.

2. Evaluación del diagrama de flujo comercial

Archivo adjunto: 02_Flujo_Comercial_Con_Notas.pdf. Conservar el proceso como hipótesis operativa de referencia. No asumir que representa el procedimiento implementado.

ID	Paso del dibujo	Tipo	Evaluación y validación
F-01	Solicitud del cliente → vendedor → móvil/CRM	D + S	Las funciones comerciales existen; canal y secuencia exactos deben verificarse.
F-02	Autorización y perfil válido	C	Prueba de permisos por rol y propiedad de datos; no está probado el control.
F-03	Rechazo/escalamiento y registro de evento	C	Control esperado; verificar casos negativos, bitácoras y proceso de escalamiento.
F-04	API valida operación, identidad y logs	S + C	La API existe; su posición y validaciones concretas no están documentadas.
F-05	CRM crea/actualiza órdenes	D + S	CRM gestiona órdenes; quién las modifica y cómo se autorizan requiere pruebas.
F-06	SQL Server persiste “registro e historial”	D + S	SQL almacena operaciones; tabla real de historial y ruta específica no constan.
F-07	ERP factura, cobra y concilia	D + S	Facturación y cobros documentados; conciliación automática y secuencia, no.

F-08	API/CRM/SQL/ERP → auditoría y SIEM	C	Verificar fuentes de log, cobertura, integridad, sellado horario y revisión.
F-09	Estado verificable de orden y factura	C	Es objetivo de control y trazabilidad, no resultado ya demostrado.

3. Matriz de preguntas y pruebas a coordinar

Propuestas de auditoría para el Paso 5 (programa de pruebas) y el Paso 6 (papeles de trabajo). Los IDs P3 son temporales: el Integrante 1 asignará R-XX y T-XX; el Integrante 3 documentará PT-XX y custodia.

ID	Pregunta de auditoría	Evidencia/prueba que se solicitaría	Referencias
P3-01	¿Los perfiles de móvil/CRM/API limitan consultas y cambios?	Inventario de roles; matriz de permisos; pruebas autorizadas sobre datos sintéticos.	Alertas 09; E-01 / E-05
P3-02	¿Accesos externos privilegiados requieren MFA y aprobación?	Configuración IAM/VPN, nómina de terceros, aprobaciones y sesiones.	Alertas 01–03; E-01 / E-02
P3-03	¿Se pueden atribuir y conciliar los 216 cambios de órdenes?	Logs CRM, bitácoras SQL, cuentas, autorizaciones y conciliación ERP.	E-03 / E-05 / E-06
P3-04	¿La integración fue desplegada con aprobación y pruebas?	Ticket, repositorio, despliegues, autorización y validación post-cambio.	Alerta 04; E-06
P3-05	¿El monitoreo recoge fuentes completas y gestiona las alertas?	Fuentes y retención de SIEM, relojes, registro de alerta y cierre.	Alerta 08; E-07
P3-06	¿Respaldos y recuperación cumplen objetivos BIA/RTO/RPO?	Políticas y pruebas de restauración, RTO/RPO documentados y conciliación.	Alertas 07 y 11; E-08
P3-07	¿Se conoce la responsabilidad del proveedor, cloud y chatbot?	Contrato, inventario, SLA, subcontratistas, alcance SOC 2, flujo de datos.	Alertas 05 y 10; E-09 / E-10
P3-08	¿Los 1.6 GB fueron transferencia autorizada o exfiltración?	NetFlow/proxy/DNS, IP/identidad destino, horario y contenido según permiso.	E-04; evento 02:35

4. Limitaciones y reglas para evitar falsos hallazgos

- El caso presenta un inventario, alertas y una cronología preliminar; no entrega diagramas de infraestructura autenticados, bases productivas, logs íntegros o contratos completos.
- Las relaciones entre sistemas y su orden temporal o causal son supuestos verificables; una flecha dibujada no demuestra integración directa.
- Las fronteras “servicios de RedNova” y “proveedores/nube” indican agrupaciones lógicas, no acreditan propiedad, hosting ni responsabilidades contractuales.
- La línea de 02:35 (~1.6 GB) no demuestra fuga: hacen falta destino, propósito, contenido y contexto. La lectura de 31,840 registros tampoco acredita por sí sola exfiltración.
- Las pruebas sugeridas deberán realizarse con registros sintéticos o en entornos autorizados. Nunca se usarán datos personales reales para construir el laboratorio.

- Un hallazgo exige condición, criterio, evidencia identificable, causa razonada, efecto, recomendación y prioridad; debe declararse “no concluyente” si faltan pruebas.

5. Texto breve listo para integrar al informe final

Para describir los dos modelos:

“Se elaboraron diagramas de arquitectura lógica y flujo comercial de RedNova Guatemala, S. A. a partir del inventario y los procesos declarados en el caso. El modelo permite identificar activos críticos, posibles flujos de información, fronteras de confianza y puntos de control sujetos a evaluación. Dado que el expediente no incluye planos autenticados ni inventarios de interfaces, las conexiones directas entre CRM, SQL Server, ERP, API y otros servicios se consideran hipótesis técnicas, no hechos comprobados. Las decisiones de autorización, registros centralizados, conciliación y restauración se registran como controles esperados. Los riesgos derivados se trasladan al programa de pruebas y sus conclusiones dependerán de evidencia adicional suficiente.”

Para entregar al coordinador:

“Se adjuntan dos diagramas del Paso 3, una matriz de 21 elementos clasificados y ocho preguntas de auditoría. Se requiere validar la pertinencia de los riesgos, asignar códigos R-XX y T-XX y cruzar los resultados con las evidencias E-01 a E-10 y papeles PT-XX. No se han declarado hallazgos a partir del dibujo.”

6. Referencias del enunciado académico

- Proyecto Operación Trazabilidad - Auditoría de Sistemas: pág. 2 (inventario tecnológico), pág. 3 (alertas), pág. 4 (cronología), pág. 5 (E-01 a E-10), pág. 6 (Misión C y consultas).
- Guía Entregables Operación Trazabilidad: pág. 2 (Paso 3: arquitectura y flujo); págs. 3-4 (pruebas, custodia e investigación); pág. 6 (trazabilidad).
- Asignación de Roles y Entregables de Auditoría: pág. 1 (Integrante 2, Pasos 3, 7 y 8).

Criterio profesional: documentar hechos, riesgos, supuestos y límites por separado; no afirmar incumplimientos sin prueba.